

Business Requirements Document — Authentication

Platform: Zebu Helpdesk — Staff Portal (Flutter, Android/iOS) **Module:** Authentication & Onboarding **Document Version:** 1.0 (Initial Edition) **Date:** August 2026 **Status:** In Progress (case-by-case) **Classification:** Internal Use Only

Document Control

Field	Value
Document Title	Authentication — Business Requirements Document
Module Scope	The pre-session surfaces of the Staff Portal app: the Splash bootstrap screen shown while the session is restored, the auth-aware routing guard that decides where the user lands, the Login screen (username/password, remember-me, show/hide password), and the fully native multi-stage Forgot Password flow (request → email sent → enter code + new password → done). This document specifies functional behaviour only — visual styling (colours, themes, animation) is out of scope.
Audience	Quality Assurance, Product Management, Engineering
Source Truth	Flutter source at <code>lib/features/splash/splash_screen.dart</code> , <code>lib/features/auth/login_screen.dart</code> , <code>lib/features/auth/forgot_password_screen.dart</code> , <code>lib/features/auth/widgets/auth_ui.dart</code> , <code>lib/core/router/app_router.dart</code> , <code>lib/core/auth/auth_controller.dart</code>

6. Functional Requirements

6.1 AU-001 — Splash screen shown while the session is restored

Field	Value
Description	On app launch the session state is <code>unknown</code> and the app shows a Splash screen while the auth controller reads any stored session in the background. Once the controller resolves the session, the routing guard (AU-002) moves the user off the splash automatically — no user action is required.
Acceptance Criteria	- On launch (before the session is known) the Splash screen is shown as the initial route - The splash shows the app title Zebu Helpdesk, a STAFF PORTAL label, and an indeterminate loading indicator - No login form, buttons, or error messages appear on the splash - The splash requires no interaction and has no tappable controls - As soon as the session resolves, the user is routed away automatically — to the Dashboard when a session exists, or to Login when it does not (see AU-002) - The splash is never left on screen after the session state is known
Priority	<code>High</code>

6.2 AU-002 — Auth-aware routing guard directs the user to the right screen

Field	Value
Description	A single redirect guard governs which screen the user can reach based on session state. While the session is unknown the user is held on the Splash. Once known, an unauthenticated user is confined to the public auth routes (Login, Forgot Password) and any other path bounces to Login; an authenticated user landing on Splash or Login is forwarded to the Dashboard. This is what makes login "navigate on its own" — the Login screen itself does not push a route on success.
Acceptance Criteria	- While session status is unknown, every route resolves to the Splash screen - When the session is known and not authenticated: • The Login and Forgot Password routes are reachable and stay put • Any other route redirects to Login - When the session is known and authenticated: • Being on Splash or Login redirects to the Dashboard • All other (protected) routes are allowed - After a successful sign-in (AU-009), the auth state flips to authenticated and the guard forwards the user to the Dashboard — the Login screen does not navigate directly - After sign-out or a session-expiry event, the state flips to unauthenticated and protected routes redirect back to Login
Priority	High

6.3 AU-003 — Login screen contents

Field	Value
Description	The Login screen presents a single sign-in form. This case specifies the elements present and their order; individual field behaviour is covered in later cases.
Acceptance Criteria	- The screen is vertically scrollable so all content is reachable on short screens / with the keyboard open - The form shows, top to bottom: • An overline reading exactly STAFF PORTAL • A heading reading exactly Welcome back • A subtitle reading exactly Sign in to continue to your helpdesk • The username field (AU-004) • The password field (AU-005) • A row with Remember me (AU-006) and a Forgot password? link (AU-007) • The Sign in button (AU-008) • A footer reading exactly Trouble signing in? Contact your administrator. - Login failures are surfaced per AU-009 (inline field errors / toast), not as a persistent top banner
Priority	High

6.4 AU-004 — Username / email field

Field	Value
Description	The first form field accepts the agent's username or email. The typed text is forced to uppercase while typing, but because helpdesk logins are case-insensitive the value is lowercased when submitted. The field is required.

Field	Value
Acceptance Criteria	- The field has a label reading exactly Email or username - Text typed into the field is displayed in UPPERCASE as the user types - Autocorrect and typing suggestions are disabled for the field - On submit, the value is trimmed and converted to lowercase before being sent to the server - If the field is empty (or whitespace only) when Sign in is pressed, an inline validation error Required is shown and no request is made - A server-side field error keyed to the username is shown inline under this field (see AU-009) - The keyboard's "next" action moves focus to the password field
Priority	High

6.5 AU-005 — Password field with show/hide toggle

Field	Value
Description	The second form field accepts the password, obscured by default, with a toggle to reveal or re-hide it. It is required, and submitting from this field triggers sign-in.
Acceptance Criteria	- The field has a label reading exactly Password - The password is obscured (masked) by default - A trailing toggle control switches the password between masked and visible; its tooltip reads Show password while masked and Hide password while visible - If the field is empty when Sign in is pressed, an inline validation error Required is shown and no request is made - A server-side field error keyed to the password (<code>passwd</code>) is shown inline under this field (see AU-009) - The keyboard's "done" action submits the sign-in (AU-008)
Priority	High

6.6 AU-006 — "Remember me" persists the username only

Field	Value
Description	A "Remember me" toggle lets the agent have their username pre-filled next time. Only the username is stored (lowercased); the password is never persisted. On a later launch, a remembered username is pre-filled (shown uppercase to match the field) and the toggle is pre-ticked.
Acceptance Criteria	- The actions row shows a checkbox labelled Remember me; the whole row is one tap target and exposes a <code>checked</code> state to screen readers - The username is persisted only after a successful sign-in, and only when the toggle is on; it is stored in lowercase form - The password is never stored under any circumstances - When the toggle is off at successful sign-in, any previously remembered username is cleared - On a subsequent launch, if a remembered username exists it is pre-filled into the username field (displayed uppercase) and the toggle starts ticked - The toggle cannot be changed while a sign-in is in progress
Priority	Medium

6.7 AU-007 — "Forgot password?" link opens the reset flow

Field	Value
Description	A "Forgot password?" link on the actions row opens the Forgot Password flow (AU-011 onward) as a pushed screen the user can back out of.
Acceptance Criteria	- A link reading exactly Forgot password? appears on the actions row - Tapping it pushes the Forgot Password screen (AU-011) - The link is disabled while a sign-in is in progress - Returning from the Forgot Password screen restores the Login screen with its entered username intact
Priority	Medium

6.8 AU-008 — Sign in button with busy state

Field	Value
Description	The primary action is a "Sign in" button. While a sign-in request is in flight it shows a busy indicator and blocks re-submission.
Acceptance Criteria	- The button label reads exactly Sign in - While a sign-in request is in flight the button shows a busy/loading indicator in place of its label and is not tappable (no duplicate submissions) - Sign-in can also be triggered by the "done" action from the password field (AU-005) - The button returns to its normal tappable state when the request completes (success or failure)
Priority	High

6.9 AU-009 — Sign in submission, validation, and error handling

Field	Value
Description	Pressing Sign in validates the form, then calls the login endpoint. On success the auth state flips to authenticated and the router forwards the user to the Dashboard (AU-002). On failure, server field errors are shown inline against the matching fields; a general (non-field) error is shown as an error toast; any unexpected error shows a generic toast.
Acceptance Criteria	- Any previous inline field errors are cleared at the start of a submit - If client validation fails (empty username or password), the request is not made and inline Required errors are shown (AU-004, AU-005) - On a valid form, the username (trimmed, lowercased) and password are sent to the login endpoint - On success: • The username is persisted or cleared per the Remember-me setting (AU-006) • The auth state becomes authenticated and the router navigates to the Dashboard — the screen does not push a route itself - On an API error that carries field errors, each error is shown inline beneath its field (username → username field, <code>passwd</code> → password field) - On an API error with no field errors, the error message is shown as an error toast (SnackBar) - On any other/unexpected error, an error toast reading exactly Unexpected error. Please try again. is shown - The busy state is always cleared when the request completes, whatever the outcome
Priority	High

6.10 AU-010 — Login footer help text

Field	Value
Description	A static footer line under the sign-in button tells the agent who to contact if they cannot sign in.
Acceptance Criteria	- A footer line reads exactly Trouble signing in? Contact your administrator. - The text is non-interactive (not a link)
Priority	Low

6.11 AU-011 — Forgot Password: Request stage

Field	Value
Description	The first stage of the Forgot Password flow lets the agent enter their username or email to request a reset email. A shortcut link lets a user who already has a code jump straight to the reset stage.
Acceptance Criteria	- The stage shows an overline Forgot password, a heading Reset it, and a subtitle explaining a reset link will be sent - A single required field with hint Username or email is shown and auto-focused - A primary button reads Send reset link - Tapping Send (or submitting from the field) validates the field is non-empty, then calls the request-reset endpoint; while in flight the button shows a busy indicator (AU-008 behaviour) - On success the flow advances to the Email-sent stage (AU-012), carrying the server's returned message - On an API error, the error message is shown as an error toast; on any other error a toast reading exactly Something went wrong. Please try again. is shown - A link reading exactly Already have a reset code from the email? Enter it advances directly to the Reset stage (AU-013) - A Back to sign in link returns to the Login screen
Priority	High

6.12 AU-012 — Forgot Password: Email-sent confirmation stage

Field	Value
Description	After a reset request succeeds, a confirmation stage tells the agent to check their email and offers to proceed to entering the reset code.
Acceptance Criteria	- A heading reads exactly Check your email - A body message shows the server-returned message if present; otherwise it falls back to exactly: If an account matches, a password reset email has been sent. Follow the link in the email to reset your password. - A primary button reads I have a reset code; tapping it advances to the Reset stage (AU-013) - A Back to sign in link returns to the Login screen
Priority	Medium

6.13 AU-013 — Forgot Password: Enter code + new password stage

Field	Value
Description	The reset stage collects the emailed reset code and a new password (entered twice). It validates the code is present, the password is at least 6 characters, and the confirmation matches, then calls the reset endpoint. Server errors are mapped to the relevant field.

Field	Value
Acceptance Criteria	- The stage shows an overline Reset password, a heading New password, and a subtitle instructing the user to paste the code and choose a new password - Three fields are shown: • Reset code — required, auto-focused • New password — obscured with a show/hide toggle, required and must be at least 6 characters (else inline At least 6 characters) • Confirm password — obscured, must equal the New password (else inline Passwords do not match) - The show/hide toggle switches masking for both password fields together - A primary button reads Reset password; submitting from the confirm field also triggers it - On success the flow advances to the Done stage (AU-014) - On an API error: • An <code>invalid_token</code> error is shown inline under the Reset code field • A <code>new_password</code> field error (or a generic validation error) is shown inline under the New password field • Any other error is shown as an error toast - Empty required fields show inline Required and block the request
Priority	High

6.14 AU-014 — Forgot Password: Done / success stage

Field	Value
Description	The final stage confirms the password was reset and returns the agent to sign-in.
Acceptance Criteria	- A heading reads exactly Password reset - A body reads exactly Your password has been updated. You can now sign in with your new password. - A primary button reads Back to sign in; tapping it returns to the Login screen - No form fields are shown on this stage
Priority	Medium

6.15 AU-015 — Forgot Password: back navigation

Field	Value
Description	Every stage of the Forgot Password flow provides a way back to sign-in: a back button at the top-left, plus a "Back to sign in" link on the request/email-sent/reset stages.
Acceptance Criteria	- A back button is present at the top-left of the Forgot Password screen on all stages; tapping it pops back toward the Login screen - The Request, Email-sent, and Reset stages also show a Back to sign in text link - Back links/buttons are disabled while a request is in flight - Backing out and returning to Login preserves the Login screen's entered username
Priority	Low

Document in progress — additional cases added after individual approval.